



Information Security Risk Register — Aetheris Therapeutics S.p.A.

Registro dei Rischi di Sicurezza dell'Informazione (ISO/IEC 27005:2022)

Standard di Riferimento: ISO/IEC 27005:2022 & ISO/IEC 27001:2022 (Clausola 6.1)
Organizzazione: Aetheris Therapeutics S.p.A.
Rif. Documento: RSK-REG-2026-02
Versione: 1.0
Stato: Approvato
Classificazione: Riservato / Per Uso d'Audit
Data di Efficacia: Agosto 2026

1. Introduzione e Metodologia di Calcolo

Il presente **Risk Register (Registro dei Rischi)** censisce e analizza i rischi per la sicurezza delle informazioni identificati durante l'audit condotto presso **Aetheris Therapeutics S.p.A.**

I punteggi sono calcolati in conformità alla metodologia aziendale (RSK-MTH-2026-01):

- * **Rischio Inerente (R_I):** Probabilità (P) × Impatto (I) allo stato attuale, prima dell'applicazione delle azioni di remediation.
- * **Rischio Residuale (R_R):** Stima del rischio residuo previsto a seguito dell'implementazione del *Risk Treatment Plan*.
- * **Soglia di Accettabilità:** Rischi con punteggio ≥ 10 (Alto/Critico) richiedono mitigazione obbligatoria.

2. Sintesi della Distribuzione del Rischio

Livello di Rischio Inerente	Range Punteggio	Conteggio Rischi Identificati	Azione Richiesta
CRITICO (Extreme Risk)	20 – 25	2	Intervento d'emergenza immediato (< 30 giorni)
ALTO (High Risk)	10 – 16	3	Mitigation plan prioritario (< 90 giorni)
MEDIO (Medium Risk)	5 – 9	2	Trattamento a medio termine (< 180 giorni)
BASSO (Low Risk)	1 – 4	1	Accettato / Monitoraggio continuo

3. Registro Dettagliato dei Rischi Identificati

RISK-01: Compromissione Credenziali Remote e Compromissione Rete tramite VPN (No MFA)

- **Asset Coinvolto:** Infrastruttura di Rete, Connessione VPN, Tenant Azure
- **Minaccia / Vulnerabilità:** Attacco Brute-Force / Password Spraying favorito dall'assenza di autenticazione a più fattori (MFA) sul gateway VPN (NC-MAJ-01).
- **Impatto Potenziale:** Accesso non autorizzato da remoto, movimento laterale, esfiltrazione di dati R&D.
- **Valutazione Inerente (R_I):**
 - Probabilità (P): **5 (Molto Alta)** | Impatto (I): **4 (Maggiore)** → **Punteggio: 20 (CRITICO)**
 - **Trattamento Proposto:** Implementazione MFA obbligatorio con Conditional Access Azure AD e integrazione SAML.
 - **Controlli ISO 27001 / NIST:** Annex A.5.15, A.8.5 | NIST PR.AC-3

- **Target Residuale (R_R):**
 - Probabilità (P): **1 (Molto Bassa)** | Impatto (I): **4 (Maggiore)** → **Punteggio: 4 (BASSO / ACCETTABILE)**
-

RISK-02: Movimento Laterale ed Escalation dei Privilegi tramite Account Domain Admin Condivisi

- **Asset Coinvolto:** Active Directory Domain Controllers, Server R&D
 - **Minaccia / Vulnerabilità:** Compromissione di una singola utenza amministrativa condivisa e assenza di tracciabilità/PAM (NC-MAJ-02).
 - **Impatto Potenziale:** Compromissione totale dell'intera foresta Active Directory, cifratura ransomware dei server.
 - **Valutazione Inerente (R_I):**
 - Probabilità (P): **4 (Alta)** | Impatto (I): **5 (Catastrofico)** → **Punteggio: 20 (CRITICO)**
 - **Trattamento Proposto:** Disattivazione account condivisi, creazione admin nominali MFA e adozione vault PAM.
 - **Controlli ISO 27001 / NIST:** Annex A.5.18, A.8.2 | NIST PR.AC-4
 - **Target Residuale (R_R):**
 - Probabilità (P): **1 (Molto Bassa)** | Impatto (I): **5 (Catastrofico)** → **Punteggio: 5 (MEDIO / TOLERABILE)**
-

RISK-03: Fuga e Compromissione dei Dati Sensibili dei Pazienti (PII/GDPR)

- **Asset Coinvolto:** Database Clinici, Portali R&D, Workstation Ricercatori
 - **Minaccia / Vulnerabilità:** Assenza del Registro Trattamenti Art. 30 GDPR (NC-MAJ-04) e mancanza di controlli DLP sulle uscite dati.
 - **Impatto Potenziale:** Data breach di dati sanitari sensibili, sanzioni amministrative dal Garante GDPR (fino a 20M € / 4% fatturato) e grave danno reputazionale.
 - **Valutazione Inerente (R_I):**
 - Probabilità (P): **4 (Alta)** | Impatto (I): **4 (Maggiore)** → **Punteggio: 16 (ALTO)**
 - **Trattamento Proposto:** Mappatura dati Art. 30 GDPR, implementazione Microsoft Purview DLP ed encryption sui dati PII.
 - **Controlli ISO 27001 / NIST:** Annex A.5.34, A.8.12 | NIST ID.GV-3, PR.DS-4
 - **Target Residuale (R_R):**
 - Probabilità (P): **2 (Bassa)** | Impatto (I): **3 (Moderato)** → **Punteggio: 6 (MEDIO / TOLERABILE)**
-

RISK-04: Mancata Rilevazione Tempestiva di Attacchi Informatici e Ransomware

- **Asset Coinvolto:** Log di Sistema, Firewall Palo Alto, Endpoint R&D
 - **Minaccia / Vulnerabilità:** Assenza di una piattaforma SIEM/SOC per il monitoraggio h24 e la correlazione degli eventi (NC-MAJ-05).
 - **Impatto Potenziale:** Persistenza inosservata di cyber-minacce all'interno della rete per mesi (Dwell Time elevato).
 - **Valutazione Inerente (R_I):**
 - Probabilità (P): **4 (Alta)** | Impatto (I): **4 (Maggiore)** → **Punteggio: 16 (ALTO)**
 - **Trattamento Proposto:** Integrazione log su Microsoft Sentinel ed ingaggio servizio Managed SOC/MSSP h24.
 - **Controlli ISO 27001 / NIST:** Annex A.8.15, A.8.16 | NIST DE.AE-3, DE.CM-1
 - **Target Residuale (R_R):**
 - Probabilità (P): **2 (Bassa)** | Impatto (I): **2 (Minore)** → **Punteggio: 4 (BASSO / ACCETTABILE)**
-

RISK-05: Errore o Ritardo nel Contenimento di Incidenti per Assenza di IRP

- **Asset Coinvolto:** Tutti i Servizi IT e la Produzione R&D
- **Minaccia / Vulnerabilità:** Assenza di un Incident Response Plan formale e di procedure di escalation ed emergenza (NC-MAJ-03).
- **Impatto Potenziale:** Amplificazione dei danni durante un attacco, blocco prolungato dell'operatività, mancata notifica nei tempi legali (72h GDPR).
- **Valutazione Inerente (R_I):**
 - Probabilità (P): **3 (Media)** | Impatto (I): **4 (Maggiore)** → **Punteggio: 12 (ALTO)**
- **Trattamento Proposto:** Redazione IRP conforme a NIST SP 800-61, definizione Incident Response Team e test annuali Tabletop.
- **Controlli ISO 27001 / NIST:** Clausola 5.24, Annex A.5.26 | NIST RS.RP-1
- **Target Residuale (R_R):**
 - Probabilità (P): **1 (Molto Bassa)** | Impatto (I): **3 (Moderato)** → **Punteggio: 3 (BASSO / ACCETTABILE)**

RISK-06: Presenza di Shadow IT e Asset Non Tracciati per Gestione Manuale ITAM

- **Asset Coinvolto:** Endpoints, Server, Dispositivi di Rete
- **Minaccia / Vulnerabilità:** Mantenimento manuale dell'inventario hardware/software tramite fogli Excel (NC-MIN-01).
- **Impatto Potenziale:** Impossibilità di garantire la copertura di patch/antivirus su dispositivi non censiti, introduzione di vulnerabilità non gestite.
- **Valutazione Inerente (R_I):**
 - Probabilità (P): **3 (Media)** | Impatto (I): **3 (Moderato)** → **Punteggio: 9 (MEDIO)**
- **Trattamento Proposto:** Implementazione di un software di IT Asset Management e discovery di rete automatizzata.
- **Controlli ISO 27001 / NIST:** Annex A.5.9 | NIST ID.AM-1, ID.AM-2
- **Target Residuale (R_R):**
 - Probabilità (P): **1 (Molto Bassa)** | Impatto (I): **2 (Minore)** → **Punteggio: 2 (BASSO / ACCETTABILE)**

RISK-07: Compromissione della Supply Chain tramite Fornitori SaaS Non Controllati

- **Riferimento Asset:** Portali SaaS Terzi, Servizi Cloud Integrati
- **Minaccia / Vulnerabilità:** Assenza di addendum di sicurezza e diritto di audit nei contratti di fornitura terzi (NC-MIN-04).
- **Impatto Potenziale:** Data breach indiretto derivante dalla compromissione delle infrastrutture di un fornitore critico.
- **Valutazione Inerente (R_I):**
 - Probabilità (P): **3 (Media)** | Impatto (I): **3 (Moderato)** → **Punteggio: 9 (MEDIO)**
- **Trattamento Proposto:** Definizione di una procedura di Supplier Risk Management, censimento fornitori e richiesta evidenze SOC2/ISO 27001.
- **Controlli ISO 27001 / NIST:** Annex A.5.19 | NIST ID.SC-3
- **Target Residuale (R_R):**
 - Probabilità (P): **1 (Molto Bassa)** | Impatto (I): **3 (Moderato)** → **Punteggio: 3 (BASSO / ACCETTABILE)**

RISK-08: Infezione da Ransomware Evoluto su Workstation R&D

- **Asset Coinvolto:** Laptop e Workstation dei Laboratori R&D

- **Minaccia / Vulnerabilità:** Utilizzo di antivirus tradizionale basato unicamente su firme senza funzionalità EDR (OFI-01).
- **Impatto Potenziale:** Cifratura locale dei dati di ricerca non ancora sincronizzati nei backup.
- **Valutazione Inerente (R_I):**
 - Probabilità (P): 2 (Bassa) | Impatto (I): 2 (Minore) → **Punteggio: 4 (BASSO)**
 - **Trattamento Proposto:** Migrazione a una soluzione EDR basata su analisi comportamentale ed isolamento automatico dell'host.
 - **Controlli ISO 27001 / NIST:** Annex A.8.7 | NIST DE.CM-4
 - **Target Residuale (R_R):**
 - Probabilità (P): 1 (Molto Bassa) | Impatto (I): 1 (Insignificante) → **Punteggio: 1 (BASSO / ACCETTABILE)**

4. Matrice di Sintesi dei Rischi: Inerente vs Residuale

ID Rischio	Oggetto del Rischio	Rischio Inerente (R_I)	Stato Inerente	Rischio Residuale (R_R)	Stato Residuale Target
RISK-01	Accessi VPN Remoti senza MFA	20	🔴 CRITICO	4	✅ BASSO
RISK-02	Account Admin Condivisi (No PAM)	20	🔴 CRITICO	5	🟡 MEDIO
RISK-03	Fuga Dati Sensibili PII/GDPR	16	🔴 ALTO	6	🟡 MEDIO
RISK-04	Assenza di SIEM / Monitoring h24	16	🔴 ALTO	4	✅ BASSO
RISK-05	Assenza Incident Response Plan	12	🔴 ALTO	3	✅ BASSO
RISK-06	Gestione Manuale Asset IT	9	🟡 MEDIO	2	✅ BASSO
RISK-07	Rischi Supply Chain e SaaS	9	🟡 MEDIO	3	✅ BASSO
RISK-08	Infezione Endpoint R&D	4	✅ BASSO	1	✅ BASSO

5. Controllo Documentale e Approvazione (ISO 27001:2022 Clausola 7.5)

Ruolo	Nome e Cognome	Stato	Data
Redatto da (Lead Auditor)	Emanuele Tarchi	Completato	Agosto 2026
Revisionato da (IT Director)	IT Director ad interim	Revisionato	Agosto 2026
Approvato da (Alta Direzione)	Chief Executive Officer (CEO)	Approvato	Agosto 2026